信息安全与保密技术作业

2026—2027 学年第一学期

姓名：_____　　学号：_____　　班级：_____

1、1、下图中 SSL 的作用是什么？



答：图中是网易 126 邮箱（126.com）的登录页面，页面上提供了“SSL 安全登录”选项。SSL（Secure Sockets Layer，安全套接层）是位于 TCP/IP 协议栈传输层与应用层之间的安全协议（其后续版本为 TLS），它利用公开密钥密码技术，在客户机与服务器之间建立一条安全的通信通道，为 HTTP、SMTP、POP3、FTP 等高层应用协议提供安全保障。其作用主要有四个方面：

（1）身份鉴别（认证）：通过服务器数字证书验证服务器的真实身份（必要时也验证客户端身份），防止攻击者假冒网站实施“中间人”攻击和网络钓鱼。

（2）数据保密（机密性）：对应用层数据加密后再传输，登录时提交的邮箱账号、口令等敏感信息在链路上以密文形式出现，即使数据包被截获也无法直接读出明文。

（3）数据完整（完整性）：利用消息认证码（MAC）校验数据是否被篡改，防止报文在传输途中被修改、删除或插入。

（4）抗重放：借助序号、随机数等机制，防止攻击者重放截获的报文。

因此在本图中，勾选“SSL 安全登录”后，浏览器与 126 邮件服务器之间的会话将以 HTTPS（HTTP over SSL）方式进行，用户输入的账号和口令被加密传输，从而避免口令在

公网上以明文形式被窃听。

2、下图中小锁的作用是什么?



答：小锁（锁形图标）是 SSL/TLS 加密连接的状态标志，是“当前连接是安全的”这一状态的直观提示，其作用包含三层含义：

（1）提示连接已加密：表示浏览器与服务器之间已经成功建立了 SSL/TLS 安全通道（地址栏以 https://开头），页面与服务器之间传输的数据均经过加密，第三方无法窃听其内容。

（2）提示服务器身份已通过验证：所访问站点的数字证书由受信任的证书颁发机构（CA）签发且在有效期内，说明访问的是真实站点而非假冒站点。

（3）作为查看证书的入口：单击小锁通常可以查看该站点的证书信息，包括颁发者、有效期、加密算法和加密强度等。

需要强调的是：小锁本身并不提供加密功能，它只是对“已经加密”这一事实的标识。如果小锁消失、变成打开的锁或出现红色警告，则说明当前连接未加密或证书存在问题，此时不应输入账号、口令等敏感信息。图中该小锁与“SSL 安全登录”选项相配合，表示选择该选项后登录过程中的账号和口令将以密文形式传输。

3、信息安全的 CIA 指的是什么？

答：CIA 是信息安全三个最基本属性（安全目标）的英文缩写：

（1）C——机密性（Confidentiality）：保证信息不泄露给未授权的用户、实体或过程，即只有获得授权者才能访问信息，且信息在存储和传输中不被非法获知。通常通过数据加密、访问控制、防电磁泄漏等手段实现。

（2）I——完整性（Integrity）：保证信息在存储、传输和处理过程中不被非授权地修改、删除、插入或伪造，即数据始终保持真实、完整的状态。通常通过散列函数（Hash）、消息认证码（MAC）、数字签名等手段实现。

（3）A——可用性（Availability）：保证授权用户在需要时能够及时、可靠地访问信息和信息系统，即系统不因非授权者的行为而拒绝服务。通常通过冗余备份、容错技术、抗拒绝服务攻击、灾难恢复等手段实现。

CIA 三者相互联系、缺一不可，共同构成信息安全的基石。在此基础上，信息安全还常补充可控性（Controllability）、不可否认性/抗抵赖性（Non-repudiation）、可审查性等属性，我国通常把信息安全的属性概括为保密性、完整性、可用性、可控性和不可否认性。

4、传统世界中的安全与数字世界中的安全有什么差别？

答：传统世界中的安全与数字世界中的安全在保护对象、安全边界、威胁来源、攻防代价和防护手段等方面都存在明显差别，主要对比如下表所示。

比较项	传统世界中的安全	数字世界中的安全
保护对象	有形实体：人身、财物、房屋、文件载体	无形信息：数据、程序、账号、隐私
安全边界	边界明确，可设围墙、门禁、哨卡	无固定边界，网络可达之处即边界
威胁来源	需要物理接近，攻击者必须到场	可来自世界任何地点，远程即可实施
距离因素	距离是天然屏障，越远越难攻击	距离基本失去意义，跨国攻击与本地无异
攻击代价	较高，需工具、人力与时间，风险大	很低，可自动化、批量化、匿名化
复制扩散	实物被窃即失去，复制困难	信息可无损复制，成本近乎为零，泄露后无法收回
痕迹取证	痕迹明显，现场可以勘查	痕迹易被删除或伪造，取证困难
防护手段	物理手段：锁、围墙、警卫、保险柜	逻辑手段：密码技术、身份认证、访问控制、审计
安全目标	主要防盗窃、防破坏、防人身	机密性、完整性、可用性、可

	伤害	控性、抗抵赖性
攻防态势	攻防相对对称，易守难攻	攻防不对称，易攻难守，安全是动态的、相对的

归结起来，二者最本质的差别是：传统安全保护的是“看得见、摸得着”的实体，主要依靠物理屏障；数字安全保护的是可以无限复制、无边界流动的信息，只能依靠密码学等逻辑手段，而且不存在“绝对安全”，只能追求“足够安全”，并通过持续的管理和技术措施把风险控制在可接受的范围之内。

5、通信系统的典型攻击形式有哪些？

答：按照通信过程中攻击者对数据流的作用方式，通信系统的典型攻击形式分为被动攻击和主动攻击两大类：

1. 被动攻击（只窃听、不改变数据流，隐蔽性强，难以发现，但可以预防）

（1）截获（窃听）：攻击者在通信链路上搭线窃听，或接收无线信道的信号，直接获取通信内容。

（2）流量分析：当通信内容已经加密而无法读懂时，通过分析通信双方的地址、通信频度、报文长度和通信时间规律等，推断出有价值的机密信息。

2. 主动攻击（篡改或伪造数据流，容易被发现，但难以彻底预防，重点是检测）

（3）中断（阻断）：破坏通信链路或系统资源，使通信无法进行、服务不可用，如拒绝服务攻击（DoS/DDoS）、切断通信线路、破坏路由器等。

（4）篡改：截获报文后修改其内容再转发，如改变报文中的数据、延迟或重排报文顺序。

（5）伪造：攻击者假冒合法用户身份或伪造报文注入网络，如重放攻击、假冒身份、伪造数据等。

概括地说，被动攻击有截获和流量分析两种，主动攻击有中断、篡改、伪造（含重放）等形式。对付被动攻击以预防（加密）为主，对付主动攻击则以检测和恢复为主。

6、ISO 7498-2 定义的五大类安全服务是什么？

答：ISO 7498-2《信息处理系统——开放系统互连——基本参考模型 第 2 部分：安全体系结构》定义了五大类安全服务（也称安全功能）：

（1）鉴别（认证）服务：证实通信实体或数据来源的身份与其声称的一致，包括对等实体鉴别和数据源鉴别两种，主要用于防止假冒。

（2）访问控制服务：防止未经授权的用户访问系统资源或利用系统资源，即防止对资源的非授权使用。

（3）数据机密性服务：保护数据不被非授权者获知，包括连接机密性、无连接机密性、选择字段机密性和业务流机密性。

（4）数据完整性服务：防止数据被非授权地修改、插入、删除或重放，包括带恢复的连接完整性、无恢复的连接完整性、选择字段连接完整性和无连接完整性等。

（5）抗抵赖（不可否认）服务：防止通信双方事后否认曾经发生过的通信或操作，包括原发抗抵赖、交付抗抵赖等，通常依靠数字签名实现。

这五类安全服务由 ISO 7498-2 同时定义的八种安全机制来支持实现，即加密机制、数字签名机制、访问控制机制、数据完整性机制、鉴别交换机制、业务流填充机制、路由控制机制和公证机制。

7、简述现有的安全模型有哪些？

答：安全模型是对安全策略所表达的安全需求进行精确、无歧义、简洁的描述，是安全策略的形式化表达，也是设计与实现安全系统的依据。现有的安全模型大体可以分为以下几类：

1. 访问控制类模型

（1）自主访问控制模型（DAC）：基于访问控制矩阵或访问控制表（ACL），由资源拥有者自行决定授权，如 UNIX 的文件权限，灵活但安全性较弱。

（2）强制访问控制模型（MAC）：由系统按主体和客体的安全级别强制授权，用户不能自行更改。典型代表有 Bell-LaPadula 模型（保证机密性，实行“下读上写”）、Biba 模型（保证完整性，实行“上读下写”）、Clark-Wilson 模型（商业完整性模型）和 Chinese Wall 模型（利益冲突模型）。

（3）基于角色的访问控制模型（RBAC）：通过“角色”把主体与权限解耦，按岗位授权，便于管理，是目前应用最广泛的模型之一。

2. 信息流类模型

信息流模型检查信息在主体、客体之间流动的方向是否符合安全策略；格模型（Lattice Model）是其数学基础；非干扰模型（Non-interference Model）用于分析多级安全系统中的隐蔽通道。

3. 状态机类模型

用状态机描述系统的安全状态及其迁移，Bell-LaPadula、Biba 等模型均可用状态机表示；Harrison-Ruzzo-Ullman（HRU）模型研究授权系统的安全性判定问题。

4. 面向网络与动态防护的安全模型

（1）通信安全模型（Shannon 模型）：在不可信信道上通过加密实现保密通信，安全性依赖于密钥的保密，同时需要一条安全的密钥分发信道。

（2）访问控制安全模型（参考监视器/安全内核模型）：通过访问控制矩阵、能力表、安全内核和可信计算基（TCB）实现访问控制。

（3）动态安全模型：P2DR 模型（策略 Policy、防护 Protection、检测 Detection、响应

Response）、PDRR 模型（增加恢复 Recovery）、PPDR 模型等；我国提出的 WPDRRC 模型包括预警、保护、检测、响应、恢复、反击六个环节。

5. 其他模型

多级安全模型（MLS）、BMA 模型，以及面向云计算、物联网的新型模型，如“永不信任、始终验证”的零信任（Zero Trust）模型等。

8、ISO 7498-2，TCSEC，DES 分别是由哪个机构制定的？

答：三者的制定机构分别如下：

（1）ISO 7498-2：由国际标准化组织（ISO，International Organization for Standardization）制定，全称为《信息处理系统——开放系统互连——基本参考模型第 2 部分：安全体系结构》（ISO 7498-2:1989），是 OSI 安全体系结构的基础标准。我国对应的标准是 GB/T 9387.2。

（2）TCSEC：由美国国防部（DoD，Department of Defense）制定，具体由其下属的国家计算机安全中心（NCSC）和国家安全局（NSA）组织实施，1985 年发布，编号 DoD 5200.28-STD，因封面为橙色而俗称“橙皮书”，全称《可信计算机系统评估准则》。它把计算机系统的安全划分为 D、C1、C2、B1、B2、B3、A1 共七个等级。

（3）DES：由美国国家标准局（NBS，National Bureau of Standards，即现在的美国国家标准与技术研究院 NIST）制定，1977 年作为联邦信息处理标准 FIPS PUB 46 发布，全称《数据加密标准》（Data Encryption Standard），是一种分组长度为 64 位、有效密钥长度为 56 位的对称分组密码算法。

补充：RSA 算法由美国麻省理工学院的 Rivest、Shamir 和 Adleman 三人提出并由 RSA 公司推广；AES 由 NIST 于 2001 年制定；CC（通用准则）由 ISO/IEC 与美国、加拿大、欧洲共同制定；我国的 GB 17859-1999 由原国家质量技术监督局发布。

9、信息系统的物理安全包含哪些内容？

答：物理安全（也称实体安全）是整个信息系统安全的基础，指为保证信息系统免遭自然灾难、环境事故和人为破坏，保护计算机设备、设施（含网络）及其他媒体免遭破坏所采取的措施。其内容主要包括：

（1）环境安全（机房与场地安全）：机房的选址与建筑结构安全（防震、防雷、防水、防潮），温湿度控制，防火与消防，防静电、防尘、防有害气体，防电磁干扰，以及电力供应与接地保护（UPS、稳压电源、防雷接地）等。

（2）设备安全：设备的防盗、防毁、防电磁信息泄漏（电磁屏蔽、电磁干扰、TEMPEST 技术）、防线路窃听；设备的冗余与备份（双机热备、磁盘阵列）；设备的日常维护与故障处理。

（3）媒体（介质）安全：存储介质（磁盘、磁带、光盘、U 盘等）的防盗、防毁、防

霉变和防磁场干扰；介质中数据的登记、归档与保密管理；废弃介质的销毁（消磁、粉碎、物理销毁），防止数据被恢复。

（4）人员安全：人员的安全审查，权限与职责分离，出入机房的身份识别与门禁管理，值班与巡检制度，安全教育与培训，以及人员离岗、离职的交接管理。

（5）管理安全（制度保障）：物理安全管理制度、机房管理制度、设备与介质管理制度、应急预案与灾难恢复计划等。

10、我国制定了哪几个安全等级？

答：我国参照国际标准（TCSEC、ITSEC、CC 等）并结合本国国情，制定了国家标准 GB 17859-1999《计算机信息系统安全保护等级划分准则》，将计算机信息系统的安全保护能力划分为五个等级：

第一级：用户自主保护级——通过隔离用户与数据，使用户具备自主安全保护的能力（自主访问控制），保护用户信息免受非授权访问，是最低等级。

第二级：系统审计保护级——在第一级的基础上增加了审计功能，要求创建并维护访问对象的审计记录，能够追踪到每个用户的访问行为，并实施客体重用控制（对应 TCSEC 的 C2 级）。

第三级：安全标记保护级——在第二级的基础上增加了强制访问控制，为每个主体和客体设置敏感标记，系统按标记实施强制访问控制，并具有审计、客体重用、数据完整性等保护能力（对应 B1 级）。

第四级：结构化保护级——在第三级的基础上，把自主访问控制和强制访问控制扩展到系统的全部主体与客体，建立形式化的安全策略模型，对隐蔽通道进行分析，并在系统结构上划分为关键保护部分与非关键保护部分（对应 B2 级）。

第五级：访问验证保护级——最高等级，在第四级的基础上，系统的安全内核必须满足引用监视器的要求并能够被形式化验证，具有抗渗透能力和可信恢复能力（对应 B3/A1 级）。

此外，2008 年发布的 GB/T 22239《信息安全技术 信息系统安全等级保护基本要求》（现行版本为 GB/T 22239-2019，即“等保 2.0”）按信息系统受到破坏后对公民、法人和其他组织的合法权益，以及社会秩序、公共利益和国家安全的危害程度，把信息系统划分为第一级至第五级共五个安全保护等级（自主保护级、指导保护级、监督保护级、强制保护级、专控保护级），这是我国开展信息安全等级保护工作的依据。

11、对称密码与非对称密码的区别?

答：对称密码（单钥密码）与非对称密码（公钥密码）的主要区别如下：

（1）密钥使用不同：对称密码的加密密钥与解密密钥相同，或虽不相同但由其中一个很容易推出另一个；非对称密码使用一对密钥——公钥和私钥，加密与解密（或签名

与验证）使用不同的密钥，并且由公钥在计算上不能推出私钥。

（2）密钥管理与分发不同：对称密码要求通信双方必须通过安全信道预先共享密钥，n 个用户两两通信需要 n(n-1)/2 个密钥，密钥管理困难，难以解决密钥分发和陌生人之间的保密通信问题；非对称密码的公钥可以公开（通过证书发布），n 个用户只需 n 对密钥（2n 个），密钥管理简单，便于密钥分发和数字签名。

（3）算法基础不同：对称密码基于替代、置换、异或等基本运算，通过多轮迭代实现混淆与扩散，安全性依赖于密钥的保密（算法可以公开）；非对称密码基于数学难题——大整数因子分解（RSA）、离散对数（ElGamal、DH）、椭圆曲线离散对数（ECC），安全性依赖于数学问题的计算复杂性。

（4）运算速度与适用数据量不同：对称密码算法简单、速度快，一般比非对称密码快数百至数千倍，适合加密大量数据（文件、数据流）；非对称密码计算复杂、速度慢，一般只用于加密少量数据（如会话密钥）和数字签名。

（5）实现的功能不同：对称密码只能实现机密性（数据加密），不能实现数字签名和抗抵赖；非对称密码既可实现机密性，又可实现身份认证、数字签名和抗抵赖，还可用于密钥交换。

（6）典型算法不同：对称密码有 DES、3DES、AES、IDEA、RC4、SM4 等；非对称密码有 RSA、ElGamal、ECC、DSA、DH 等。

实际应用中常把二者结合使用：用非对称密码分发会话密钥，用对称密码加密数据（即数字信封技术），从而兼得安全性与效率。

12、分组密码与流密码的区别？

答：分组密码与流密码（序列密码）的主要区别如下：

（1）处理单位不同：分组密码把明文按固定长度分成若干组（如 64 位、128 位），以组为单位用同一密钥进行加密变换，输出等长的密文组；流密码把明文按比特（或字节）逐位处理，用密钥流（伪随机序列）与明文逐位异或产生密文。

（2）密钥流的使用方式不同：分组密码对每个分组使用相同的密钥和相同的变换，同一明文分组在同一密钥下必产生相同的密文，因此需要工作模式（ECB、CBC、CFB、OFB、CTR 等）来掩盖统计规律；流密码的密钥流由种子密钥通过伪随机发生器产生，加密变换随位置而变化，密钥流的每一位只使用一次。

（3）有无记忆（状态）不同：分组密码是无记忆的，各分组依次独立处理；流密码是有记忆的，其输出不仅与当前输入有关，还与内部的记忆状态有关。

（4）错误传播不同：分组密码（如 CBC 模式）中一位出错会影响整个分组甚至后续分组；流密码中一位密文出错只影响对应的一位明文，错误不扩散。

（5）同步要求不同：流密码（尤其是同步流密码）要求收发双方严格同步，一旦失步就无法正确解密；分组密码不需要严格同步，且支持随机访问。

（6）性能与实现不同：流密码加解密速度快、时延小、错误不扩散，适合硬件实现和实时性要求高的场合，如语音、视频等连续数据流的加密；分组密码便于软件实现和标准化，适合分组数据的加密与认证。

（7）典型算法不同：分组密码有 DES、3DES、AES、IDEA、SM4 等；流密码有 RC4、A5/1、ZUC（祖冲之）、ChaCha20 以及一次一密等。

需要指出的是，分组密码与流密码可以相互转化：分组密码的 CFB、OFB、CTR 等工作模式就可以把分组密码当作流密码使用。

13、基于攻击者所知道信息的密码分析的攻击类型有哪些？

答：按照攻击者在密码分析中所掌握的信息量由少到多（攻击强度由弱到强），攻击类型可分为以下几种：

（1）唯密文攻击：攻击者只知道若干密文以及加解密算法的细节，试图据此恢复明文或密钥。这是最困难、也是攻击者最常面对的情形。

（2）已知明文攻击：攻击者掌握若干“明文—密文”对（但明文不是由他选择的），据此推断密钥或解密算法。例如利用已知的文件头、固定格式的报文作为已知明文。

（3）选择明文攻击：攻击者可以选择任意明文并获得对应的密文（相当于他可以使用加密机），据此推断密钥。差分密码分析、线性密码分析都属于这一类。

（4）选择密文攻击：攻击者可以选择任意密文并获得对应的明文（相当于他可以使用解密机），据此推断密钥，常用于攻击公钥密码体制和数字签名方案。

（5）选择文本攻击：选择明文攻击与选择密文攻击的结合，攻击者既能选择明文获得密文，又能选择密文获得明文，是最强的攻击类型。

此外，按攻击手段还可分为穷举攻击（暴力破解）、字典攻击、中间相遇攻击、相关密钥攻击、差分分析、线性分析、代数攻击和侧信道攻击（时间分析、功耗分析、电磁分析）等。一个密码体制要被认为是安全的，通常要求它能够抵抗选择明文攻击（IND-CPA）甚至选择密文攻击（IND-CCA）。

14、古典密码的加密方法有哪些？基本思想是什么？

答：古典密码（手工密码和机械密码）的加密方法基本上可以归纳为替换和换位两大类：

1. 替换密码（Substitution Cipher）

按照一定的规则，用一个或一组字符去替换明文中的字符，字符的位置保持不变。

（1）单表替换（一个明文字符固定对应一个密文字符）：移位（加法）密码——凯撒密码（移位 3 位）、一般加法密码；乘法密码；仿射密码（$c = a \cdot m + b \bmod 26$）；密钥短语密码、关键词密码等。

（2）多表替换（同一个明文字符在不同位置对应不同的密文字符）：维吉尼亚密码

（用密钥字母控制移位量）、博福特密码、格朗普雷密码；希尔密码（用矩阵乘法对字符向量作线性变换，属于代数密码）；一次性密码本（Vernam/OTP，密钥流与明文等长且完全随机，理论上不可破）。

2. 换位密码（Transposition / Permutation Cipher）

保持明文字符本身不变，只按一定规则重新排列字符的位置。

（1）列换位密码：把明文按行写入矩阵，再按密钥规定的列顺序读出；

（2）栅栏密码（轨道密码）：把明文按一定间隔分成若干组后交叉读出；

（3）矩形换位、路游换位：按螺旋、对角线等路径读取矩阵中的字符。

3. 其他

隐写术（把秘密信息隐藏在文字、图像之中，如藏头诗、书卷密码、隐形墨水），以及替换与换位相结合的复合密码。

基本思想

（1）用“变换”代替“隐藏”：把明文变换成看似无意义的密文，安全性建立在密钥的保密上而不是算法的保密上（Kerckhoffs 原则）。

（2）混淆与扩散：这是 Shannon 提出的两个基本设计思想。替换主要产生“混淆”（confusion），使密文与密钥之间的关系尽可能复杂，让攻击者无法从密文推测密钥；换位主要产生“扩散”（diffusion），使明文中的一位变化影响密文中的许多位，把明文的统计特性散布到整个密文中。

（3）消除明文中的统计规律与冗余度：自然语言存在字母出现频率、双字母组合等统计特征，多表替换和复合密码正是为了打乱这些统计规律，使攻击者难以用频率分析等方法破译。

（4）以密钥控制变换：同一算法在不同密钥下产生不同的变换，密钥空间要足够大，使穷举攻击不可行。

古典密码大多已能被频率分析、已知明文攻击等方法破译，但它们所确立的替换与换位、混淆与扩散等思想，至今仍是现代分组密码（如 DES、AES）设计的基础。